Netzwerkanalyse mit Nmap und Wireshark

Grundlagenpraktikum zur IT-Sicherheit (WiSe 2023/2024)

Lehrstuhl für Netz- und Datensicherheit
Ruhr-Universität Bochum

Nico S**** Sabri Öztürk

1. Mai 2026

Zusammenfassung

In einem Netzwerk werden vielen Daten versendet und von verschiedenen Personen empfangen. Diese Daten können abgefangen und ausgewertet werden, um z.B. in erfahrng zu bringen, welche Internetseiten von einem Computer aufgerufen, welche Bilder angeschaut und welche Nutzerdaten verwendet wurden. Wie eine Netwerkanalyse funktionert und welche Daten wirklich einsehbar sind, wird in diesem Versuch in erfahrung gebracht.

Inhaltsverzeichnis

1 Einleitung **1**

1.1 Glossar 1

2 Aufbau **2**

3 Durchführung **3**

3.1 Netzwerktopologie 3

3.2 Stealth-Scan 4

3.3 Betriebsystemerkennung 5

3.4 Untersuchung des Netzwerkverkehrs 6

3.5 Finden von Passwörtern 11

4 Responsible disclosure **13**

5 Zusammenfassung und Fazit **14**

6 LLM **15**

1 Einleitung

Wie Netzwerke aufgebaut sind und wer alles Zugang zu einem Netzwerk hat, ist nicht immer direkt ersichtlich. Durch die vielen verschiedenen Geräte, wie Computer, Drucker, Server oder auch nur das Smartphone, werden viele verschiedene Daten ausgetauscht und nicht alle Endgeräte und Daten sind so gut geschützt, wie die mehrheit der Menschen vielleicht denkt.

Durch verschiedene Digitale-Werkzeuge wie *Nmap* und *Wireshark* kann das Netzwerk durchsucht werden. So kann eine Topologie des Netzwerks erstellt werden, in welcher erreichbare IP-Adressen, offene Ports und auch das genutzte Betriebsystem aufgelistet sind. Zudem kann mitgeschnitten werden, welche Daten in einem Netzwerk ausgetauscht werden. So können Angreifer Nutzernamen und Passwörter mitschneiden, wenn diese über unsichere Protokolle ausgetauscht werden.

Im Verlauf dieses Versuchs wird das Netzwerk über verschiedene Methoden, wie Port- und Stealth-Scans, untersucht. So ist es möglich zu erfahren, wie viele und welche Geräte im lokalen Netwerk aktiv sind. Angreifer können diese Art Informationen zu böswilligen Zwecken nutzen und mögliche Schwachstellen suchen und ausnutzen. Zudem wird gezeigt, welche Informationen durch mitschneiden des Netwerkverkehrs gewonnen werden können, welche Protokolle das Mitschneiden von Informationen zulassen und welche kaum Informationen preisgeben.

1.1 Glossar

Nmap eine Software, welche das Scannen von Netzwerken, nach Teilnehmern, offenen Ports der Teilnehmer und weiteren Informationen ermöglicht

Wireshark eine Software, welche Daten im Netzwerk mitschneidet, die der Copmuter empfangen kann und Auswertungsmöglichkeiten der Daten bietet

IP-Adresse eine Möglichkeit einen Copmuter anzusprechen

Port eine Schnittstelle zu einem bestimmten Prozess auf einem Computer

2 Aufbau

Die folgenden Versuche wurden im Netzlabor ID 2/168 unternommen.
Wir führen den Versuch zu zweit als Gruppe 43 am PC mit der IP-Adresse 192.168.1.42 durch.
Das Betriebsystem ist ein Ubuntu 22.04 LTS.

Es wurden verschiedene Programme und Befehle genutz. Diese sind:

Software	**Version**
Nmap	7.80
Wireshark	3.6.2
ftp	tnftp 20210827
Sudo-Version	1.9.9
Sudoers-Policy-Plugin	1.9.9
sudoers-Dateigrammatik	48
Sudoers I/O plugin	1.9.9
Sudoers audit plugin	1.9.9

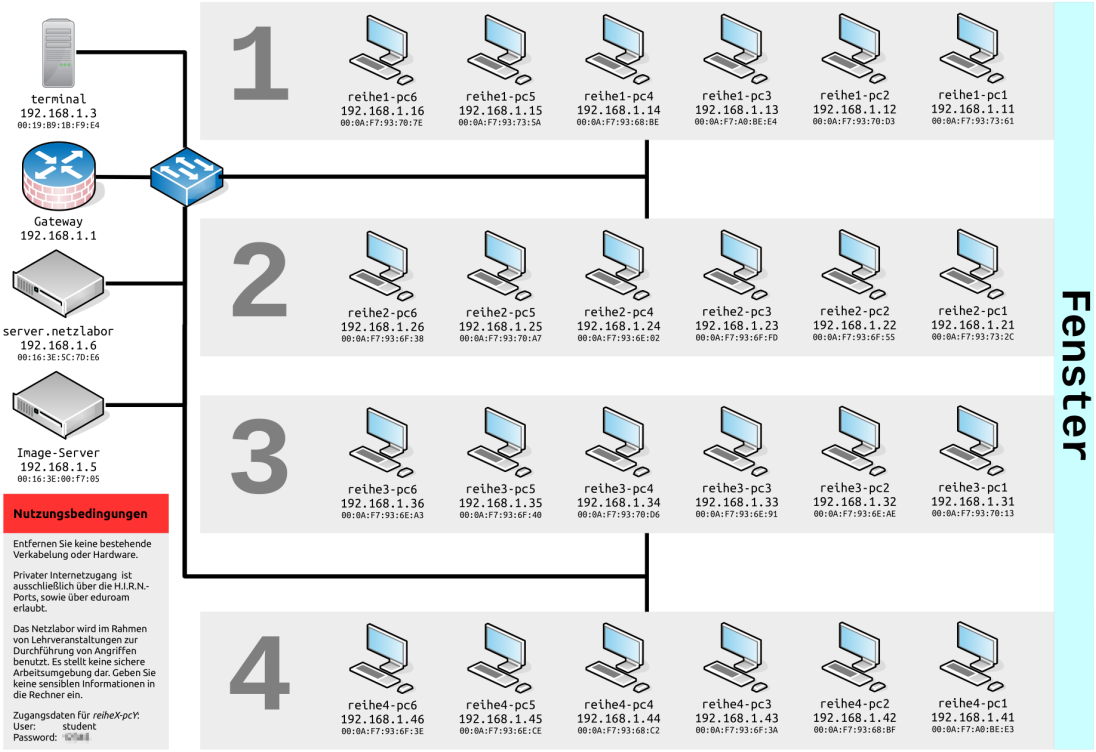


Abbildung 1: Netzplan Raum ID 2/168, Stand 01.05.2017

Die Aufgabenstellung [3] wurde bereutgestellt übe die Veranstaltungsseite [2]

3 Durchführung

Im Folgenden werden die einzelnen Aufgaben durchgeführt, erläutert und das Ergebnis präsentiert.

3.1 Netzwerktopologie

Netzwerke können komplex und undurchsichtig sein. Um einen Überblick über erreichbare Systeme zu erhalten, kann eine Software wie *Nmap* genutzt werden. *Nmap* kann ein Netzwerk auf verschiedene Art und Weisen scannen. Eine Möglichkeit ein Netzwerk nach erreichbaren Systemen und offen Ports der Systeme zu scannen ist der PING-Scan. Ein PING-Scan nutzt das Internet Control Message Protocol (ICMP) um echo requests bzw. replys, bekannter als ping, zu senden und so verfügbare Ressourcen im Netzwerk zu Überprüfen. So lässt sich der momentane Aufbau des Netzlabors ID 2/168 mit dem beigefügten Netzplan (siehe 'Abbildung 1') vergleichen.
Der Befehl *nmap* muss als Administrator (root) ausgeführt werden, da sonst einige Scan-Varianten nicht ausgeführt werden können. Über die Flag *-sP* wird ein PING-Scan gestartet und auf die angegebene IP-Adresse ausgeführt. Der Asterisk-Operator '*' sorgt dafür, dass alle 256 möglichen IP-Adressen im lokalen Netzwerk gescannt werden.

```
student@Reihe4-PC2:~$ sudo nmap -sP 192.168.1.*
[sudo] Passwort für student:
Starting Nmap 7.80 ( https://nmap.org ) at 2023-11-08 09:21 CET
Nmap scan report for _gateway (192.168.1.1)
Host is up (0.00023s latency).
MAC Address: 24:A4:3C:3C:A9:0B (Ubiquiti Networks)
Nmap scan report for Terminal (192.168.1.3)
Host is up (0.00027s latency).
MAC Address: 18:FD:74:6E:B5:CE (Unknown)
Nmap scan report for VM-Server (192.168.1.4)
Host is up (0.00027s latency).
MAC Address: 84:2B:2B:52:79:FF (Dell)
Nmap scan report for Image-Server (192.168.1.5)
Host is up (0.00032s latency).
MAC Address: 00:16:3E:4D:5D:A3 (Xensource)
Nmap scan report for fog-image-server (192.168.1.10)
Host is up (0.00034s latency).
MAC Address: 00:16:3E:5E:9D:A9 (Xensource)
Nmap scan report for reihe1-pc1 (192.168.1.11)
Nmap scan report for reihe1-pc2 (192.168.1.12)
Nmap scan report for reihe1-pc4 (192.168.1.14)
Nmap scan report for reihe1-pc5 (192.168.1.15)
Nmap scan report for reihe1-pc6 (192.168.1.16)
Nmap scan report for Reihe2-PC1 (192.168.1.21)
Nmap scan report for Reihe2-PC2 (192.168.1.22)
Nmap scan report for Reihe2-PC3 (192.168.1.23)
Nmap scan report for Reihe2-PC4 (192.168.1.24)
Nmap scan report for Reihe2-PC5 (192.168.1.25)
Nmap scan report for Reihe2-PC6 (192.168.1.26)
Nmap scan report for Reihe3-PC1 (192.168.1.31)
Nmap scan report for Reihe3-PC3 (192.168.1.33)
Nmap scan report for Reihe3-PC4 (192.168.1.34)
Nmap scan report for Reihe3-PC5 (192.168.1.35)
Nmap scan report for Reihe3-PC6 (192.168.1.36)
Nmap scan report for Reihe4-PC1 (192.168.1.41)
Nmap scan report for Reihe4-PC3 (192.168.1.43)
Nmap scan report for Reihe4-PC4 (192.168.1.44)
Nmap scan report for Reihe4-PC5 (192.168.1.45)
Nmap scan report for Reihe4-PC6 (192.168.1.46)
Nmap scan report for Reihe4-PC2 (192.168.1.42)

Nmap done: 256 IP addresses (27 hosts up) scanned in 1.33 seconds
```

Die Ausgabe ist nach Fünf Beispielen gekürzt um:

```
Host is up ([time in seconds] latency).
MAC Address: [MAC-ADDRESS] (Unknown)
```

Aus der Ausgabe des Scans geht hervor, dass 27 IP-Adressen, also 27 Geräte im Netzwerk erreichbar sind. Es fallen einige Unterschiede zum Netzplan (siehe 'Abbildung 1') auf. Im Scan kann in Zeile 10 ein
VM-Server mit der IP-Adresse *192.168.1.4* ausgemacht werden. Dieser Server ist jedoch nicht auf dem Netzplan (siehe 'Abbildung 1') verzeichnet. Auch wird *server.netzlabor* mit der angeblichen IP-Adresse *192.168.1.6* nicht gefunden. Weiter wird der Server mit dem Hostnamen *for-image-server* und der IP-Adresse *192.168.1.10* gefunden, obwohl dieser laut Netzplan (siehe 'Abbildung 1') nicht existiert.
Von den PCs in den Reihen 1 bis 4 (siehe 'Abbildung 1') sind, bis auf *192.168.1.13* und *192.168.1.32*, alle erreichbar. Möglicherweise waren die beiden PCs abgeschaltet und so nicht auf dem Scan verzeichnet.

3.2 Stealth-Scan

Der vorher durchgeführte PING-Scan, kann von den betroffenen Systemen erkannt und aufgezeichnet werden. Um dies zu verhindern, gibt es sogenannte *Stealth-Scans*. Diese Art der Scans nutz TCP/IP, ein Protokoll um Verlustfrei Daten zu übertragen, um Informationen über das System hinter der angegebenen IP-Adresse zu ermitteln. Bei TCP/IP Nachrichten, wird zu Beginn ein SYN-Packet an das Ziel geschickt. Dies kann mit einem 'Hallo' verglichen werden. Das Ziel schickt nun ein SYN- und ACK-Packet zurück. Dies ist eine Antwort auf das erste 'Hallo'. Wenn nun keine weitere Nachricht geschickt wird, bricht das Ziel die Verbindung ab und behält keine Aufzeichnungen des Verbindungsversuchs. So kann ein Scan durchgeführt werden, der nicht entdeckt wird. Zudem können spezifische Ports angesprochen werden. Diese Ports, wenn sie aktiv sind, geben Informationen über die Anwendung hinter dem Protokoll zurück. So kann eine Liste möglicher Schwachstellen erstellt werden. Die Flag *-sS* setzt den Scan-Modus als SYN-Scan fest. Es wird der Server *Image-Server* mit der IP-Adresse *192.168.1.5* nach offenen Ports und Anwendungen gescannt.

```
student@Reihe4-PC2:~$ sudo nmap -sS 192.168.1.5
[sudo] Passwort für student:
Starting Nmap 7.80 ( https://nmap.org ) at 2023-11-08 10:52 CET
Nmap scan report for Image-Server (192.168.1.5)
Host is up (0.00027s latency).
Not shown: 997 closed ports
PORT    STATE SERVICE
22/tcp  open  ssh
80/tcp  open  http
443/tcp open  https
MAC Address: 00:16:3E:4D:5D:A3 (Xensource)

Nmap done: 1 IP address (1 host up) scanned in 0.24 seconds
```

In der Ausgabe von *Nmap* ist zusehen, dass drei Ports auf dem Zielsystem geöffnet sind. Der ersten gefundenen Port 22 ist mit dem Service *ssh* verbunden. *ssh* steht für *secure shell* und bietet die Möglichkeit, eine Shell auf dem System von einem anderen Computer im Netzwerk zu öffnen[1]. Weiterhin sind die Ports 80 und 443 geöffnet. Aus der *SERVICE* Zeile kann abgelesen werden, dass dort *http* und *https* aktiv sind. Dies kann bedeuten, dass eine Webserver auf dem Server aktiv ist. Alle weiteren Ports sind geschlossen, es laufen also nur diese drei Services auf dem Server.

3.3 Betriebsystemerkennung

Es können, mit Hilfe von *Nmap*, Ports nach möglichen Anwendungen durchsucht werden. Über verschiedene Informationen, die Geräte im Netzwerk über sich Preisgeben, kann das Betriebsystem des jeweiligen Geräts geschätzt werden. Je nach Menge der Informationen kann der Scan ein einzelnes Betreibsystem oder eine Liste von möglichen Betriebsystemen ausgeben[4].

```
student@Reihe4-PC2:~$ sudo nmap -O 192.168.1.*
Starting Nmap 7.80 ( https://nmap.org ) at 2023-11-08 09:33 CET
Nmap scan report for _gateway (192.168.1.1)
Host is up (0.00040s latency).
[Port-Information]
MAC Address: 24:A4:3C:3C:A9:0B (Ubiquiti Networks)
Device type: general purpose
Running: Linux 3.X|4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.9
Network Distance: 1 hop

Nmap scan report for Terminal (192.168.1.3)
Host is up (0.00051s latency).
[Port-Information]
MAC Address: 18:FD:74:6E:B5:CE (Unknown)
[Liste Linux-Versionen]
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

Nmap scan report for VM-Server (192.168.1.4)
Host is up (0.00056s latency).
[Port-Information]
MAC Address: 84:2B:2B:52:79:FF (Dell)
[Liste Linux-Versionen]
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

Nmap scan report for Image-Server (192.168.1.5)
Host is up (0.00054s latency).
[Port-Information]
MAC Address: 00:16:3E:4D:5D:A3 (Xensource)
[Liste Linux-Versionen]
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

Nmap scan report for fog-image-server (192.168.1.10)
Host is up (0.00052s latency).
[Port-Information]
MAC Address: 00:16:3E:5E:9D:A9 (Xensource)
[Liste Linux-Versionen]
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

Nmap scan report for reihe1-pc1 (192.168.1.11)
Host is up (0.00052s latency).
[Port-Information]
MAC Address: 00:0A:F7:93:73:61 (Broadcom)
[Liste Linux-Versionen]
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

[...]

OS detection performed. Please report any incorrect results at https://nmap.org/submit/
    .
Nmap done: 256 IP addresses (27 hosts up) scanned in 19.08 seconds
```

Die Ausgabe wurde um alle PCs der Reihen 1 bis 4, bis auf Reihe 1 PC 1, die offenen Ports und die Liste der möglichen Linux-Versionen, aufgrund von Wiederholungen oder Unwichtigkeit, gekürtzt.
Liste möglicher Linux-Versionen:

```
Aggressive OS guesses: Linux 2.6.32 - 3.13 (96%), Infomir MAG-250 set-top box (95%),
    Linux 3.10 - 4.11 (94%), Linux 2.6.32 (94%), Linux 3.2 - 4.9 (94%), Linux 2.6.32 -
    3.10 (93%), HP P2000 G3 NAS device (93%), Ubiquiti AirMax NanoStation WAP (Linux
    2.6.32) (92%), MikroTik RouterOS 6.19 (Linux 3.3.5) (92%), Linux 3.7 (92%)
```

In der Ausgabe kann beobachtet werden, dass alle erreichbaren Geräte eine Version von Linux benutzen. Bis auf *_gateway* mit der IP-Adresse *192.168.1.1*, wurde allen anderen Geräten eine Liste möglicher Betriebsysteme zugeordnet. Doch jedes Gerät benutzt ein Linux Betriebsystem. Der Betriebsystem-Scan von *Nmap* hat nicht genug Daten erhalten können, um das genaue Betriebsystem eines jeden Geräts zu ermitteln.

3.4 Untersuchung des Netzwerkverkehrs

Über einen Zeitraum von 5 Minuten wird der Sniffer aktiviert, während im Internet gesurft wird, um den entstehenden Datenverkehr aufzuzeichnen. Anschließend wird der Abschnitt 'Statistiken' im Menü'Eigenschaften der Mittschnittdatei' bzw. 'Comments Summary' betrachtet.

Statistik

Messwerte	Aufgezeichnet	Angezeigt	Markiert
Pakete	371404	371404 (100.0%)	—
Zeitspanne, s	356.977	356.977	—
Durchschnittliche pps	1040.4	1040.4	—
Durschnittliche Paketgröße, B	429	429	—
Byte	159283744	159283744 (100.0%)	0
Durschnittliche Byte/s	446 k	446 k	—
Durschnittliche Bit/s	3.569 k	3.569 k	—

Abbildung 2: Statistik des Netzwerkverkehrs

Der Filter für die Suche im aufgezeichneten Netzwerkverkehr ist auf *dns* eingestellt, um ausschließlich den Verlauf zu sehen, der über DNS gelaufen ist. Darunter werden die Domains betrachtet, die durch DNS-Anfragen identifiziert wurden. Es lässt sich erkennen, dass die IP-Adresse *192.168.1.14* eine DNS-Anfrage an das Gateway *192.168.1.1* gesendet hat.

dns

o.	Time	Source	Destination	Protocol	Length	Info
20673	0.872636034	192.168.1.14	192.168.1.1	DNS	100	Standard query 0x6390 A connectivit
20674	0.872872429	192.168.1.14	192.168.1.1	DNS	100	Standard query 0xd91c AAAA connecti
21166	1.166455652	192.168.1.1	192.168.1.14	DNS	244	Standard query response 0x6390 A co
21171	1.216371689	192.168.1.1	192.168.1.14	DNS	268	Standard query response 0xd91c AAAA
23807	11.655489932	2a05:3e00:9:2162:52…	2a05:3e00:9:2162::1	DNS	97	Standard query 0xbef3 A theuselessw
23809	11.661246479	2a05:3e00:9:2162:52…	2a05:3e00:9:2162::1	DNS	98	Standard query 0xef3d A cdn.intergi
23810	11.661356111	2a05:3e00:9:2162:52…	2a05:3e00:9:2162::1	DNS	98	Standard query 0x69f2 AAAA cdn.inte

Abbildung 3: DNS-Anfragen

Die Ressourcen werden über HTTP abgerufen. Zur Identifikation der Domains, von denen zwei mittels HTTP abgerufenen Ressourcen stammen, wird die HTTP *Requests-Statistik* verwendet.

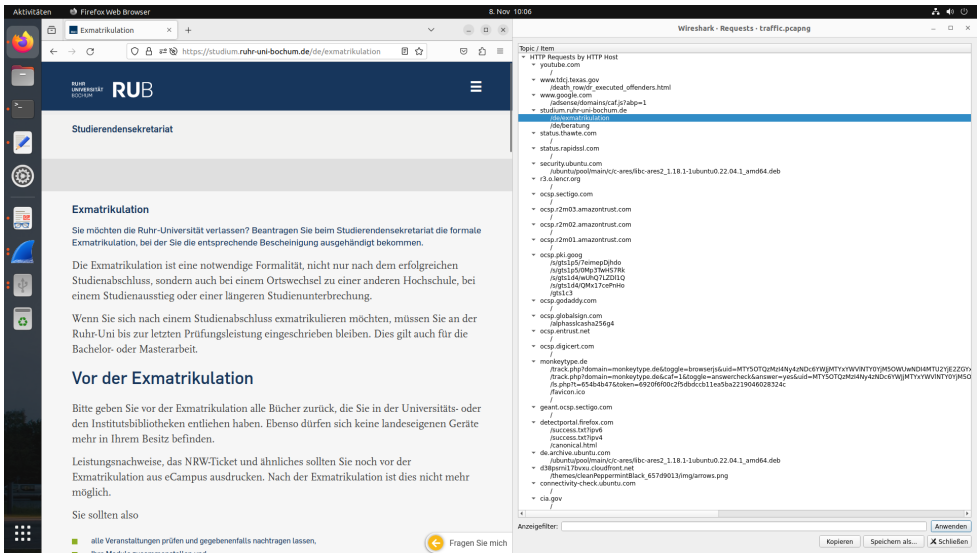


Abbildung 4: Webseite der Ruhr-Universität Bochum für die Exmatrikulation: studium.ruhr-uni-bochum.de/de/exmatrikulation

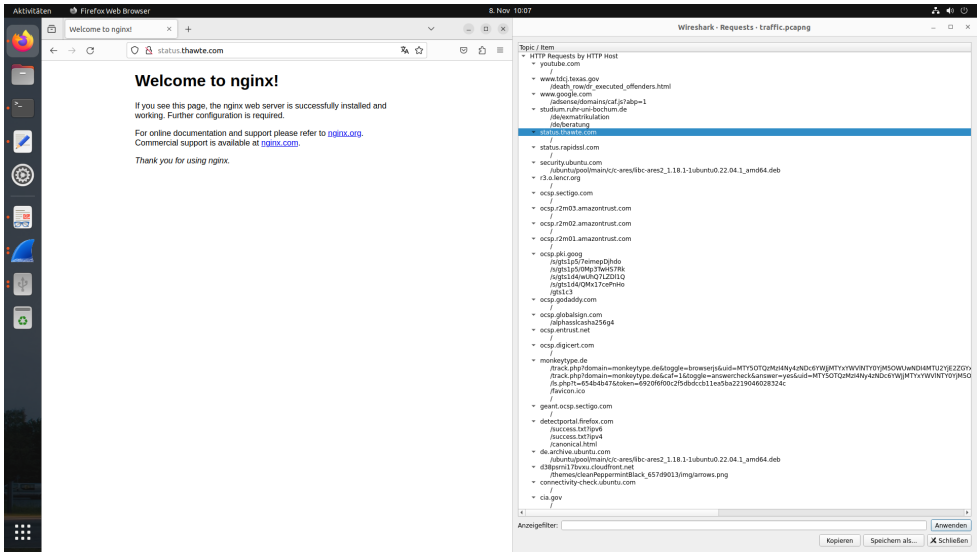


Abbildung 5: Webseite von Thawte: status.thawte.com

Im nächsten Schritt wird ein abgefangenes Bild (siehe 'Abbildung 6') gesichtet. Dafür wird die Export-Funktion unter *File/Export Objects* benutzt.

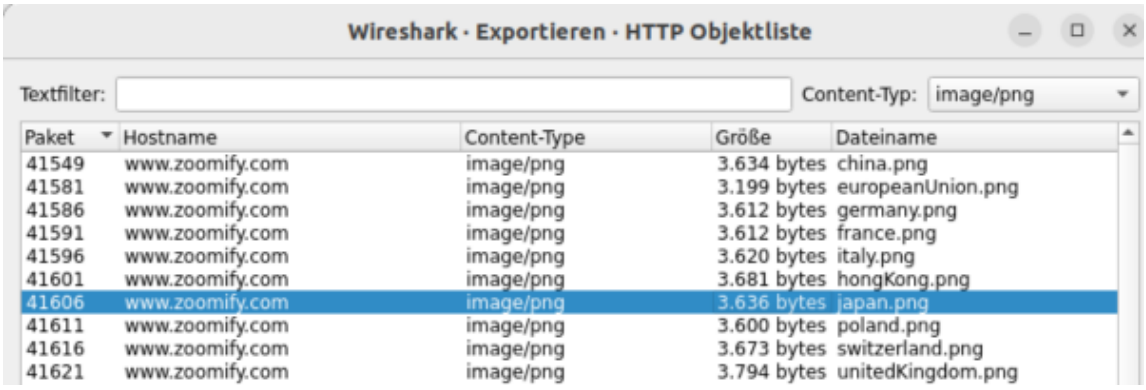


Abbildung 6: File/Export Objects

Abbildung 7: japan.png

Die Webseite 'reithuber.net', die von uns aufgerufen ist, finden wir, indem wir den Namen der Seite als Suchfilter angeben. Dazu stellen wir die Suchfilter auf 'Zeichenkette' um und geben den Name der Webseite an.

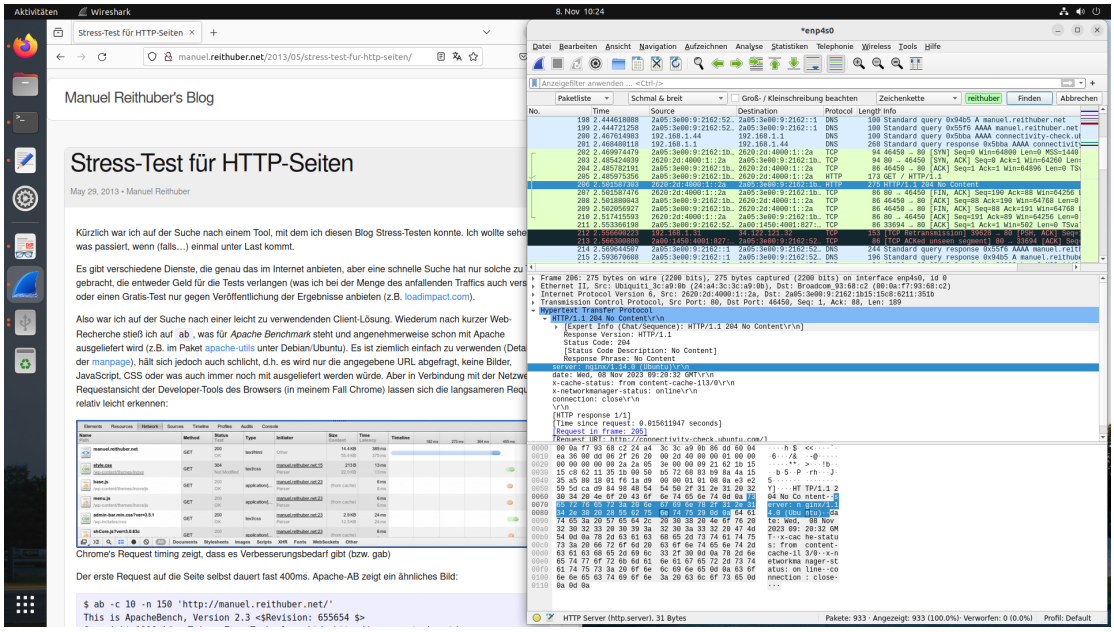
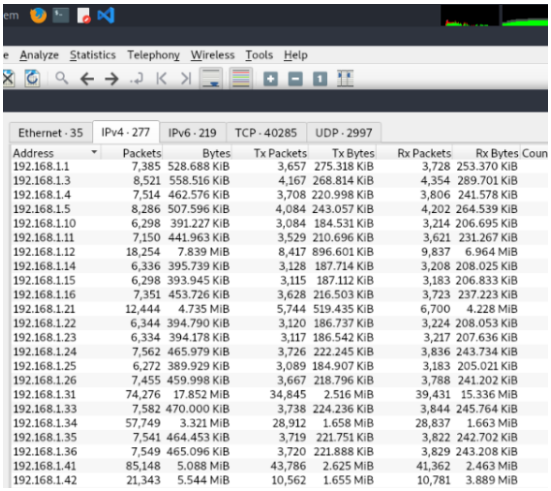


Abbildung 8: Die aufgerufene Webseite und sein Aufruf im Mitschnitt

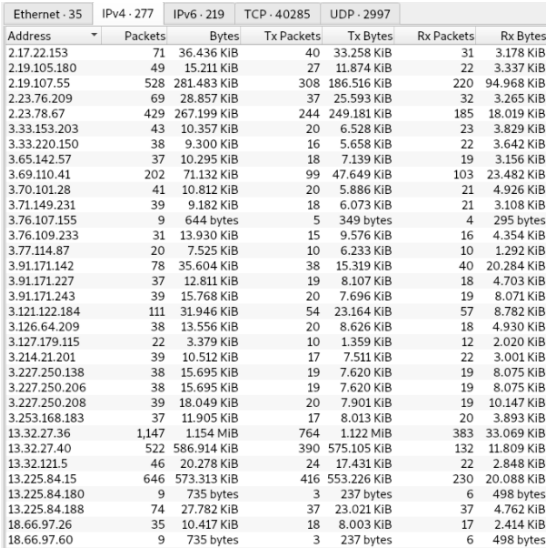
Welche Internetprotokolladressen im Mitschnitt enthalten sind, werden mittels Endpoints Statistik betrachtet. Dabei werden die Internetprotokolladressen, die sich im Internet befinden und die Internetprotokolladressen, die von Netzlabor sind, unterschieden. Die Internetprotokolladressen in Netzlabor beginnen mit dem folgenden Kette: '192.168.1', wodurch wir sie unterschieden haben.



Ethernet · 35 | IPv4 · 277 | IPv6 · 219 | TCP · 40285 | UDP · 2997

Address	Packets	Bytes	Tx Packets	Tx Bytes	Rx Packets	Rx Bytes	Coun
192.168.1.1	7,385	528.688 KiB	3,657	275.318 KiB	3,728	253.370 KiB	
192.168.1.3	8,521	558.516 KiB	4,167	268.814 KiB	4,354	289.701 KiB	
192.168.1.4	7,514	462.576 KiB	3,708	220.998 KiB	3,806	241.578 KiB	
192.168.1.5	8,286	507.596 KiB	4,084	243.057 KiB	4,202	264.539 KiB	
192.168.1.10	6,298	391.227 KiB	3,084	184.531 KiB	3,214	206.695 KiB	
192.168.1.11	7,150	441.963 KiB	3,529	210.696 KiB	3,621	231.267 KiB	
192.168.1.12	18,254	7.839 MiB	8,417	896.601 KiB	9,837	6.964 MiB	
192.168.1.14	6,336	395.739 KiB	3,128	187.714 KiB	3,208	208.025 KiB	
192.168.1.15	6,298	393.945 KiB	3,115	187.112 KiB	3,183	206.833 KiB	
192.168.1.16	7,351	453.726 KiB	3,628	216.503 KiB	3,723	237.223 KiB	
192.168.1.21	12,444	4.735 MiB	5,744	519.435 KiB	6,700	4.228 MiB	
192.168.1.22	6,344	394.790 KiB	3,120	186.737 KiB	3,224	208.053 KiB	
192.168.1.23	6,334	394.178 KiB	3,117	186.542 KiB	3,217	207.636 KiB	
192.168.1.24	7,562	465.979 KiB	3,726	222.245 KiB	3,836	243.734 KiB	
192.168.1.25	6,272	389.929 KiB	3,089	184.907 KiB	3,183	205.021 KiB	
192.168.1.26	7,455	459.998 KiB	3,667	218.796 KiB	3,788	241.202 KiB	
192.168.1.31	74,276	17.852 MiB	34,845	2.516 MiB	39,431	15.336 MiB	
192.168.1.33	7,582	470.000 KiB	3,738	224.236 KiB	3,844	245.764 KiB	
192.168.1.34	57,749	3.321 MiB	28,912	1.658 MiB	28,837	1.663 MiB	
192.168.1.35	7,541	464.453 KiB	3,719	221.751 KiB	3,822	242.702 KiB	
192.168.1.36	7,549	465.096 KiB	3,720	221.888 KiB	3,829	243.208 KiB	
192.168.1.41	85,148	5.088 MiB	43,786	2.625 MiB	41,362	2.463 MiB	
192.168.1.42	21,343	5.544 MiB	10,562	1.655 MiB	10,781	3.889 MiB	

Abbildung 9: Internetprotokolladressen von Netzlabor

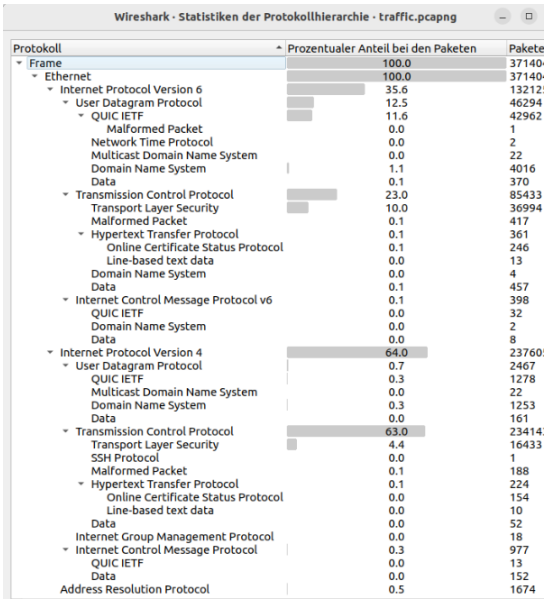


Ethernet · 35 | IPv4 · 277 | IPv6 · 219 | TCP · 40285 | UDP · 2997

Address	Packets	Bytes	Tx Packets	Tx Bytes	Rx Packets	Rx Bytes
2.17.22.153	71	36.436 KiB	40	33.258 KiB	31	3.178 KiB
2.19.105.180	49	15.211 KiB	27	11.874 KiB	22	3.337 KiB
2.19.107.55	528	281.483 KiB	308	186.516 KiB	220	94.968 KiB
2.23.76.209	69	28.857 KiB	37	25.593 KiB	32	3.265 KiB
2.23.78.67	429	267.199 KiB	244	249.181 KiB	185	18.019 KiB
3.33.153.203	43	10.357 KiB	20	6.528 KiB	23	3.829 KiB
3.33.220.150	38	9.300 KiB	16	5.658 KiB	22	3.642 KiB
3.65.142.57	37	10.295 KiB	18	7.139 KiB	19	3.156 KiB
3.69.110.41	202	71.132 KiB	99	47.649 KiB	103	23.482 KiB
3.70.101.28	41	10.812 KiB	20	5.886 KiB	21	4.926 KiB
3.71.149.231	39	9.182 KiB	18	6.073 KiB	21	3.108 KiB
3.76.107.155	9	644 bytes	5	349 bytes	4	295 bytes
3.76.109.233	31	13.930 KiB	15	9.576 KiB	16	4.354 KiB
3.77.114.87	20	7.525 KiB	10	6.233 KiB	10	1.292 KiB
3.91.171.142	78	35.604 KiB	38	15.319 KiB	40	20.284 KiB
3.91.171.227	37	12.811 KiB	19	8.107 KiB	18	4.703 KiB
3.91.171.243	39	15.768 KiB	20	7.696 KiB	19	8.071 KiB
3.121.122.184	111	31.946 KiB	54	23.164 KiB	57	8.782 KiB
3.126.64.209	38	13.556 KiB	20	8.626 KiB	18	4.930 KiB
3.127.179.115	22	3.379 KiB	10	1.359 KiB	12	2.020 KiB
3.214.21.201	39	10.512 KiB	17	7.511 KiB	22	3.001 KiB
3.227.250.138	38	15.695 KiB	19	7.620 KiB	19	8.075 KiB
3.227.250.206	38	15.695 KiB	19	7.620 KiB	19	8.075 KiB
3.227.250.208	39	18.049 KiB	20	7.901 KiB	19	10.147 KiB
3.253.168.183	37	11.905 KiB	17	8.013 KiB	20	3.893 KiB
13.32.27.36	1,147	1.154 MiB	764	1.122 MiB	383	33.069 KiB
13.32.27.40	522	586.914 KiB	390	575.105 KiB	132	11.809 KiB
13.32.121.5	46	20.278 KiB	24	17.431 KiB	22	2.848 KiB
13.225.84.15	646	573.313 KiB	416	553.226 KiB	230	20.088 KiB
13.225.84.180	9	735 bytes	3	237 bytes	6	498 bytes
13.225.84.188	74	27.782 KiB	37	23.021 KiB	37	4.762 KiB
18.66.97.26	35	10.417 KiB	18	8.003 KiB	17	2.414 KiB
18.66.97.60	9	735 bytes	3	237 bytes	6	498 bytes

Abbildung 10: Internetprotokolladressen aus Internet

Die verwendeten Protokolle können anhand der *Protokoll-Hierarchie* erkannt werden. Alle Internetpakete müssen letztendlich über IPv4 und IPv6 geleitet werden. Es ist auch ersichtlich, dass das User Data Protocol (UDP) und das Transmission Control Protocol (TCP) sehr häufig verwendet wurden.



Wireshark · Statistiken der Protokollhierarchie · traffic.pcapng

Protokoll	Prozentualer Anteil bei den Paketen	Pakete
Frame	100.0	37140
Ethernet	100.0	37140
Internet Protocol Version 6	35.6	13212
User Datagram Protocol	12.5	46294
QUIC IETF	11.6	42962
Malformed Packet	0.0	1
Network Time Protocol	0.0	2
Multicast Domain Name System	0.0	22
Domain Name System	1.1	4016
Data	0.1	370
Transmission Control Protocol	23.0	85433
Transport Layer Security	10.0	36994
Malformed Packet	0.1	417
Hypertext Transfer Protocol	0.1	361
Online Certificate Status Protocol	0.1	246
Line-based text data	0.0	13
Domain Name System	0.0	4
Data	0.1	457
Internet Control Message Protocol v6	0.1	398
QUIC IETF	0.0	32
Domain Name System	0.0	2
Data	0.0	8
Internet Protocol Version 4	64.0	23760
User Datagram Protocol	0.7	2467
QUIC IETF	0.3	1278
Multicast Domain Name System	0.0	22
Domain Name System	0.3	1253
Data	0.0	161
Transmission Control Protocol	63.0	23414
Transport Layer Security	4.4	16433
SSH Protocol	0.0	1
Malformed Packet	0.1	188
Hypertext Transfer Protocol	0.1	224
Online Certificate Status Protocol	0.0	154
Line-based text data	0.0	10
Data	0.0	52
Internet Group Management Protocol	0.0	18
Internet Control Message Protocol	0.3	977
QUIC IETF	0.0	13
Data	0.0	152
Address Resolution Protocol	0.5	1674

Abbildung 11: Protocol Hierarchy

Ein Port-Scan versucht, offene Ports zu finden, indem er von einem Server aus Verbindungsanfragen an verschiedene Ports sendet. Dabei überprüfen wir, ob von diesem Server aus viele verschiedene Hosts angepingt werden. Von derselben Quell-IP-Adresse '192.168.1.31' werden, an unterschiedliche Ports, Verbindungsanfragen gestellt. Es handelt sich so vermutlich um einen Port-Scan.

Source	Destination	Protocol
192.168.1.31	49120 192.168.1.3	80
192.168.1.31	40106 192.168.1.4	80
192.168.1.31	47634 192.168.1.5	80
192.168.1.31	59672 192.168.1.10	80
192.168.1.31	44470 192.168.1.11	80
192.168.1.31	60998 192.168.1.14	80
192.168.1.31	32972 192.168.1.15	80
192.168.1.31	51870 192.168.1.16	80
192.168.1.31	34064 192.168.1.21	80
192.168.1.31	52078 192.168.1.24	80
192.168.1.31	33320 192.168.1.25	80
192.168.1.31	44144 192.168.1.33	80
192.168.1.31	36312 192.168.1.36	80
192.168.1.31	34432 192.168.1.41	80
192.168.1.31	52372 192.168.1.42	80
192.168.1.31	34414 192.168.1.43	80
192.168.1.31	40102 192.168.1.46	80
192.168.1.31	59530 192.168.1.1	80
192.168.1.31	57770 192.168.1.12	80
192.168.1.31	54792 192.168.1.23	80
192.168.1.31	45566 192.168.1.26	80
192.168.1.31	36660 192.168.1.35	80
192.168.1.31	44034 192.168.1.45	80
192.168.1.31	59874 192.168.1.34	80
192.168.1.31	33166 192.168.1.44	80
192.168.1.31	48720 192.168.1.22	80
192.168.1.31	48318 192.168.1.34	443
192.168.1.31	43068 192.168.1.44	443
192.168.1.31	38862 192.168.1.22	443
192.168.1.31	40058 192.168.1.3	443
192.168.1.31	37412 192.168.1.4	443
192.168.1.31	52770 192.168.1.5	443
192.168.1.31	35874 192.168.1.10	443
192.168.1.31	51096 192.168.1.11	443
192.168.1.31	53512 192.168.1.12	443
192.168.1.31	40092 192.168.1.14	443
192.168.1.31	44430 192.168.1.15	443
192.168.1.31	46802 192.168.1.16	443
192.168.1.31	55150 192.168.1.21	443
192.168.1.31	51964 192.168.1.24	443
192.168.1.31	38058 192.168.1.25	443

Abbildung 12: Ein möglicher Port-Scan

Es wird ein Zertifikat einer SSL-Verbindung betrachtet. Es ist auf *Common Name* '*.adfarm1.adition.com' ausgestellt. Um dieses Zertifikat zu finden, haben wir als Suchparameter 'tls' eingegeben und die Ausgabe nach 'Protocol' sortieren lassen. Darauf folgend haben wir in allen 'TLSv1.2' Verbindungen in den Info-Abschnitt geschaut. Dort kann das 'Certificate' ausgelsen werden.

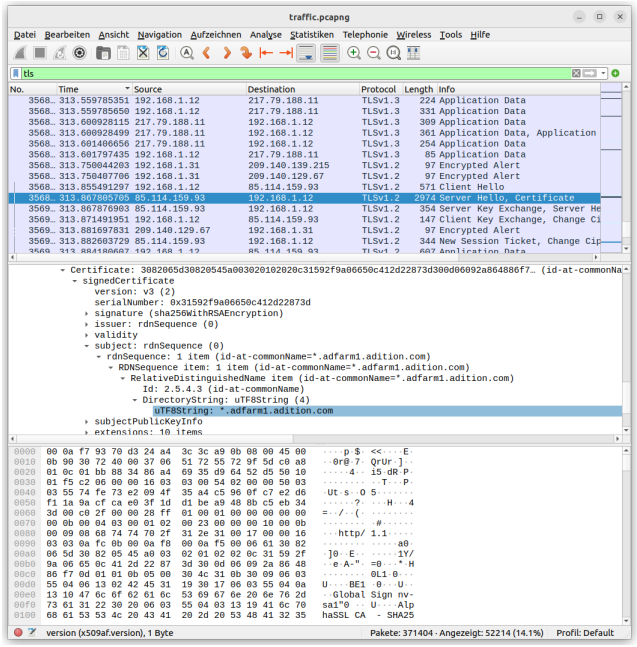


Abbildung 13: Zertifikat einer SSL-Verbindung

3.5 Finden von Passwörtern

Es werden die beiden Protokolle *FTP* und *HTTP* genutzt um sich auf verschiedenen Servern zu authentifizieren, da beide Protokolle login Informationen im Klartext übertragen. In der Konsole wird eine Verbindung zum FTP-Server unter *44.241.66.172* aufgebaut. Diese IP-Adresse gehört zu einem Dummy-Server, der für Versuche genutzt werden kann. Sobald die login Informationen eingegeben und versendet werden, können sie im Datenverkehr gesehen werden. Dazu wird der Datenverkehr in Wireshark mit dem *ftp* Filter gefiltert. Die markierten FTP-Packete enthalten unter dem Menü 'Info' zwei Requests mit den Inhalten *USER student* und *PASS password*. Dies sind die von uns gewählten login Informationen. Als nächstes wird im Browser die Webseite *http://vbsca.ca/login/login.asp* aufgerufen. Auf dieser wird ein *Username* und ein *Password* feld angezeigt. In diese können login Informationen eingetragen werden, die so über 'http' versendet werden. Sobald die Informationen gesendet wurden, kann in Wireshark nach *http.request.method == POST* gefiltert werden. Dort ist nun die POST-Requests mit den login Informationen zu sehen. Unter dem Menü 'Hypertext Transfer Protocol' kann im markierten Bereich (siehe Abbildung 15) das Passwort, test, und darüber der Username, test, gefunden werden.

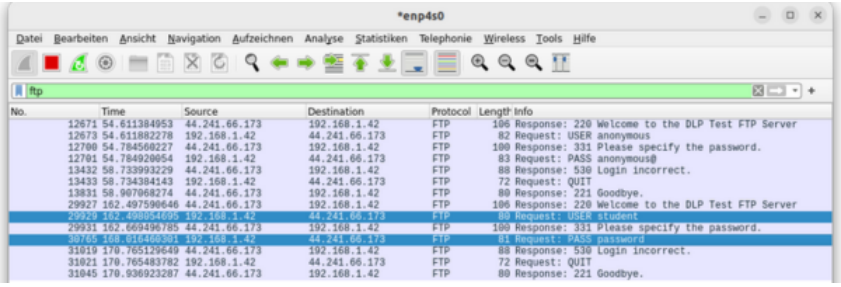


Abbildung 14: Passwort aus dem Protokoll FTP

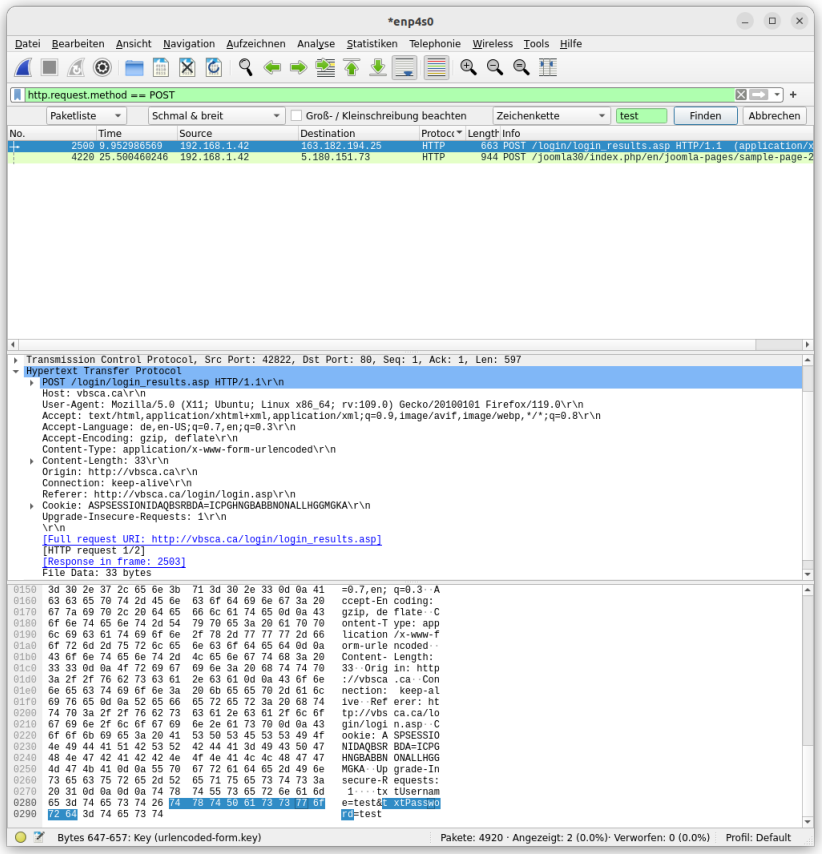


Abbildung 15: Passwort aus dem Protokoll HTTP

4 Responsible disclosure

Sehr geehrte Damen und Herren,

bei einer kürzlich erfolgten Analyse Ihrer Internetseite ist ein erhebliches Sicherheitsrisiko entdeckt worden. Daten die über Ihre Internetseite ausgetauscht werden, wie Anmeldeinformationen und Email Inhalte, sind unverschlüsselt und können von Unbefugten abgefangen und gelesen werden.

Diese Lücke betrifft alle Nutzer der Internetseite. Ein Angreifer ist in der Lage, durch das Abhören des Netzwerkverkehrs, persönliche Daten jedes Nutzers zu empfangen und zu speichern.
Dazu gehören Klartexte der versendeten Email, Anhänge und auch Nutzernamen und Passwörter. Diese Daten können benutzt werden, um Identitäten zu stehlen und ernsthaften Schaden bei den Nutzer zu verursachen.

Ihre Systemadministratoren sollten sich umgehen des Problems annehmen. Es ist empfolhen, die Internetseite vorerst außer Betrieb zu nehmen, da auch in einer kurzen Zeit verheerender Schaden angerichtet werden kann.

Die wesentliche Lücke entsteht, da Ihre Internetseite *http* verwendet, was Daten im Klartext verschickt. Eine umstellung auf *https*, was die Daten mit Hilfe des TLS Protokolls verschlüsselt, sollte schnellst möglich durchgeführt werden. Die Umstellung sollte, einer Einschätzung nach, in 14 Tagen möglich sein.

Mit freundlichen Grüßen,

Nico Steppeler und Sabri Öztürk, Berater für IT-Sicherheit

5 Zusammenfassung und Fazit

Dieser Versuch beschäftigt sich mit der Netzwerkanalyse mithilfe von *Nmap* und *Wireshark*. Durch die Netzwerkanalyse kann eine Topologie des Netzwerks erstellt werden, in der erreichbare IP-Adressen, offene Ports und sogar das genutzte Betriebssystem aufgelistet sind. Der Begriff Netzwerkanalyse bezieht sich auf den Prozess des Untersuchens, Überwachens und Auswertens von Netzwerkaktivitäten. Auf diese Weise können Probleme im Netzwerk identifiziert und behoben werden. Zudem ermöglicht die Netzwerkanalyse Optimierungen in Bezug auf Netzwerkleistung, Kapazitätsplanung und Anwendungsleistung. Was nicht genau untersucht werden kann, kann auch nicht präzise verbessert werden. Daher stellt die Netzwerkanalyse den Grundbaustein für die Funktionalität und Effizienz des Netzwerks dar.

Netzwerkanalyse ist entscheidend, um eine klare Sicht auf die Netzwerktopologie zu erhalten, Sicherheitsbedrohungen zu erkennen, die Leistung zu optimieren und Probleme proaktiv zu lösen. Insgesamt ist sie ein unverzichtbares Werkzeug für die Verwaltung und Wartung von Computernetzwerken. Im Versuch wurde gezeigt, welche Informationen durch das Mitschneiden des Netzwerks gewonnen werden können.

Die Durchführung dieses Versuchs war interessant und lehrreich. Viele wichtige Techniken wurden kennengelernt, die in Alltagssituationen für die Netzwerkanalyse hilfreich sein werden. Trotz einiger Schwierigkeiten und Hindernisse ist es uns erfolgreich gelungen, die Aufgaben abzuschließen. Die unpräzise Formulierung in der Aufgabenstellung führte zu Verständnisschwierigkeiten, und es traten zwischenzeitlich Probleme auf, die teilweise eine Überarbeitung der Aufgabenstellung erfordert haben. Zusammengefasst war der Versuch sehr nützlich und gut durchdacht.

6 LLM

In diesem Versuch wurden keine Large-Language Models(LLM) verwendet. Die Texte sind alleine die Arbeit der Mitglieder der Gruppe 43 wie zubeginn angegeben.

Literatur

[1] Ionos. Was ist eigentlich ssh? die secure shell einfach erklärt. URL https://www.ionos.de/digitalguide/server/tools/secure-shell-ssh/.

[2] Ruhr-Universität Bochum Lehrstuhl für Netz-und Datensicherheit. Bachelor Grundlagenpraktikum ITS: Veranstaltungsseite der Fakultät für Elektrotechnik und Informationstechnik. URL https://informatik.rub.de/studium/lehrveranstaltungen/.

[3] Ruhr-Universität Bochum Lehrstuhl für Netz-und Datensicherheit. Aufgabenstellung zum Praktikumsversuch. Bochum, 2023.

[4] Nmap. Usage and examples. URL https://nmap.org/book/osdetect-usage.html.